Keycloak / RHBK 26.0 → 26.6 migration

Consumer-impact validation: finding the problem before Day 1

Read-only client inventory, library runners and a per-client dashboard, tested on three Keycloak versions

The server upgrade itself can succeed while applications break, because the settings of each client are now interpreted differently. Today nobody finds out until the first morning on production. The idea: **read every client's configuration, compare it with the documented breaking changes, and show a red flag per client, long before the cut-over.**

1 · Nothing to ask of the teams

Team leads do not have to test anything. The tool reads the client settings directly from the server.

2 · Every finding has a source

Each rule points to a paragraph of the official Red Hat Upgrading Guide, so a flag is an argument, not an opinion.

3 · Safe by design

Read-only calls only. Secrets and tokens are never stored; the report is refused if one slips in.

4 · Proven on fixtures

Two test realms with known mistakes were imported into 26.0.8, 26.2.5 and 26.6.4. The result matched the expectation for all 17 clients, on all three versions.

Result in one line: **17 of 17 checks pass on each of the three versions.** The same legacy settings are flagged on the old server, so a problem is visible while it is still harmless.

How the check works

One pass over the clients, the same procedure for every Keycloak version

1. **Test realms**
   Two small realm files, with a client for every known problem plus clean ones.
2. **Keycloak containers**
   26.0.8, 26.2.5 and 26.6.4 started from the same files and the same certificate.
3. **Read-only inventory**
   Client list, client policies and discovery document are read through the Admin API.
4. **Rules**
   Each setting is compared with the documented breaking changes of 26.2, 26.4 and 26.6.
5. **Report + verdict**
   An HTML report per realm, and an automatic PASS / FAIL against the expected result.

What it answers

Which clients, in which realm, use a setting that behaves differently on the target version, and where it is documented.

Why it works without the teams

The finding comes from the server's own configuration. The weekly check by the team leads can show the same red flag per client.

What it does not answer

Runtime behaviour (token contents, session handling, proxy behaviour). Those need live probes, the next phase.

Server version needs care on 26.6: since 26.4 the server hides its version from admins that are not in the master realm, and 26.6 requires the manage-realm role for it (26.6 UG §2.10.49). When a read-only account cannot see it, the version is passed to the tool explicitly.

Rules and where they come from (1 of 2)

UG = Red Hat build of Keycloak Upgrading Guide of the named release. "Since" is the first release where the behaviour applies.

Rule	What changes for the application	Severity	Since	Official Red Hat document	Test client
C4a	Redirect URI with a wildcard in the host name (`https://*.example.org/*`) stops matching. Users can no longer log in to that application.	high	26.4.13 / 26.6.3	26.4 Upgrading Guide §2.2.1 26.6 Upgrading Guide §2.5.1	fx-c4a
C4b	`https://host*` is silently read as `https://host/*`. Narrower than before, so some callback URLs are rejected.	medium	26.4.13 / 26.6.3	26.4 UG §2.2.1 26.6 UG §2.5.1	fx-c4b
C5	Redirect URI contains `state` , `code` or `session_state` . Rejected by default (parameter pollution).	high	26.6.7	26.6 UG §2.1.2	fx-c5
C6	`http://` in post-logout, logo, policy or terms URL fails validation when the secure-client-uris policy is on.	medium	26.6.2	26.6 UG §2.6.4	fx-c6
C7	JWT client authentication accepts only one audience. Assertions with several audiences are refused.	medium	26.2	26.2 UG §2.1.4	fx-c7
C8	Standard token exchange is switched on for this client. New behaviour for token-exchange consumers; sender-constrained tokens are rejected (26.6).	medium	26.2	26.2 UG §2.1.6 26.6 UG §2.10.39	fx-c8
C10	Per-client compatibility switch for introspection / UserInfo is present. Deprecated, will be removed.	medium	26.4.12	26.4 UG §2.3.3 26.6 UG §2.6.10	not covered
C11	Client issues lightweight access tokens. The UserInfo endpoint now answers 401 for them.	medium	26.4.12	26.4 UG §2.3.4 26.6 UG §2.6.11	fx-c11

Rules and where they come from (2 of 2)

Rows marked "not covered" have no fixture client yet; live checks (D1, D2, H1) found nothing on the lab servers.

Rule	What changes for the application	Severity	Since	Official Red Hat document	Test client
C12	Web origin is not a plain `scheme://host[:port]`. Browser (CORS) calls with a non-matching Origin get HTTP 403.	low	26.6.3	26.6 UG §2.9.2	fx-c12
C16	Direct access grants (password grant) enabled. Failed login now returns HTTP 400 instead of 401; error handling in the app must follow.	low	26.6.2	26.6 UG §2.10.38	fx-c16
C15	Inventory of client authentication methods. Newly registered clients now honour exactly the method they register.	info	26.6.2	26.6 UG §2.10.29	every confidential client
P1	Public client (no secret). Outside the confidential-client test matrix, review by hand. Tool-specific, not a Keycloak change.	info	-	Project design note	fx-p1
C21	Identity-provider URLs: the server no longer follows HTTP redirects when it calls them.	info	26.4.12	26.4 UG §2.3.1 26.6 UG §2.6.8	not covered
D1	Discovery document says a different issuer than the URL you fetched it from (hostname / port / proxy mismatch).	high	26.2	26.2 UG §2.1.1	live check, no findings
D2	Root path `/.well-known/oauth-authorization-server/...` not reachable through the route (reverse proxy must expose it).	high	26.4.2	26.4 UG §2.15.12	live check, no findings
H1	Readiness check. Ports now open while Keycloak is still initialising; load balancers must probe `/health/ready`.	info	26.6.2	26.6 UG §2.6.6	live check, no findings

Result: the same findings on all three versions

Lab servers: upstream Keycloak 26.0.8-1, 26.2.5-0 and 26.6.4-1. Test realm `fx-legacy` (11 clients) and `fx-baseline` (clean).

Rule	Test client	Does the tool flag it?			Does the new behaviour apply on that server?		
		26.0.8	26.2.5	26.6.4	26.0.8	26.2.5	26.6.4
C4a	fx-c4a	**flagged**	**flagged**	**flagged**	**not yet**	**not yet**	**active**
C4b	fx-c4b	**flagged**	**flagged**	**flagged**	**not yet**	**not yet**	**active**
C5	fx-c5	**flagged**	**flagged**	**flagged**	**not yet**	**not yet**	**not yet**
C6	fx-c6	**flagged**	**flagged**	**flagged**	**not yet**	**not yet**	**active**
C7	fx-c7	**flagged**	**flagged**	**flagged**	**not yet**	**active**	**active**
C8	fx-c8	**flagged**	**flagged**	**flagged**	**not yet**	**active**	**active**
C11	fx-c11	**flagged**	**flagged**	**flagged**	**not yet**	**not yet**	**active**
C12	fx-c12	**flagged**	**flagged**	**flagged**	**not yet**	**not yet**	**active**
C16	fx-c16	**flagged**	**flagged**	**flagged**	**not yet**	**not yet**	**active**
C15	all confidential	**flagged**	**flagged**	**flagged**	**not yet**	**not yet**	**active**

Reading the table

Flagged means the tool reports the setting. *Active* means the server already enforces the new behaviour; *not yet* means it will after an upgrade. A flag with "not yet" is exactly the early warning we want.

Control group

`fx-clean`, `fx-saml`, `fx-bearer` and `fx-svc` raise no problem findings on any version.

C5 on 26.6.4

Flagged but "not yet", because the rule arrives in 26.6.7. The lab server is older than the target.

The following pages are the actual reports produced by the tool, three versions with two realms each. Colours: red = high, orange = medium, yellow = low, grey = information.

Phase 2: library runners, a real login per library

The inventory reads configuration. Runners show what happens when real code logs in.

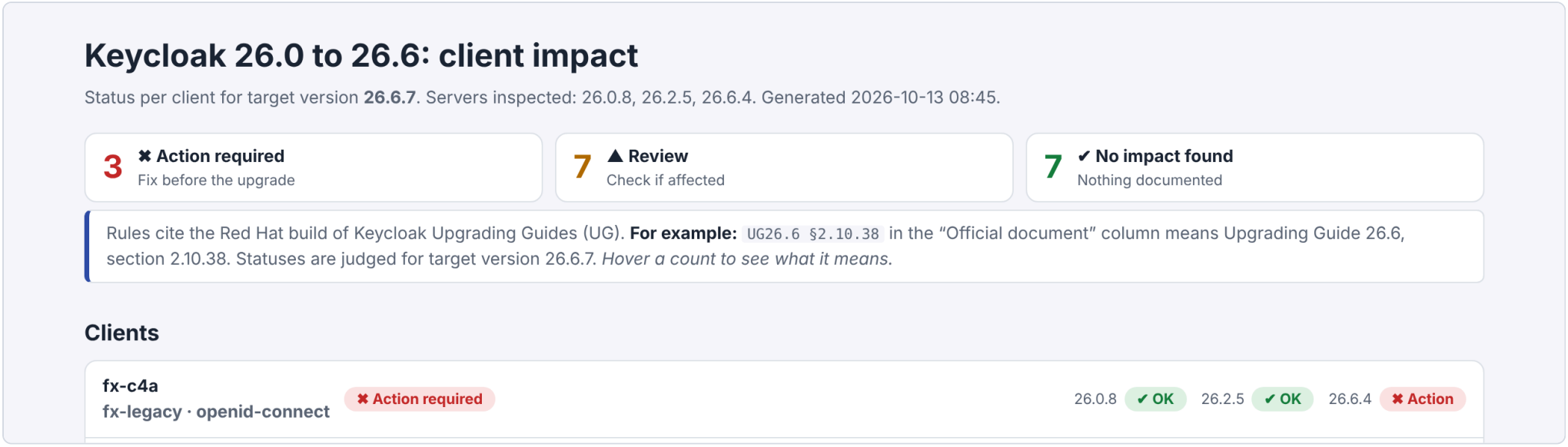
1. **Catalog**
   One entry per library: language, version, protocol, status (supported, deprecated, planned).
2. **Runner**
   A small app using that library only. Returns facts as JSON, never a verdict.
3. **Orchestrator**
   Plays the browser, submits the login, redacts tokens and secrets.
4. **Expectations**
   Data file: expected result per check and server version, with the Upgrading Guide paragraph.
5. **Dashboard**
   Library by server version matrix, and what changed between versions.

Runner	Language	Protocol	Role
http-probe	Python, stdlib	HTTP	Path probes, wrong-password status, client credentials
plain-http-code	Python, stdlib	OIDC	Control: the login flow written by hand. If it passes and a library fails, the library is the cause
passport-oauth2 1.8.0	Node	OIDC	Generic OAuth2 (does not validate the ID token itself)
flask-oidc 2.4.0	Python	OIDC	Flask applications
better-auth 1.7.1	Node	OIDC	Newer framework, generic OAuth plugin
samlify 2.13.1	Node	SAML	Service provider, signed requests
python3-saml 1.16.0	Python	SAML	Service provider
samlify <2.10.0	Node	SAML	Catalog entry only: shows a library version marked *deprecated* (CVE-2025-47949) without any code change

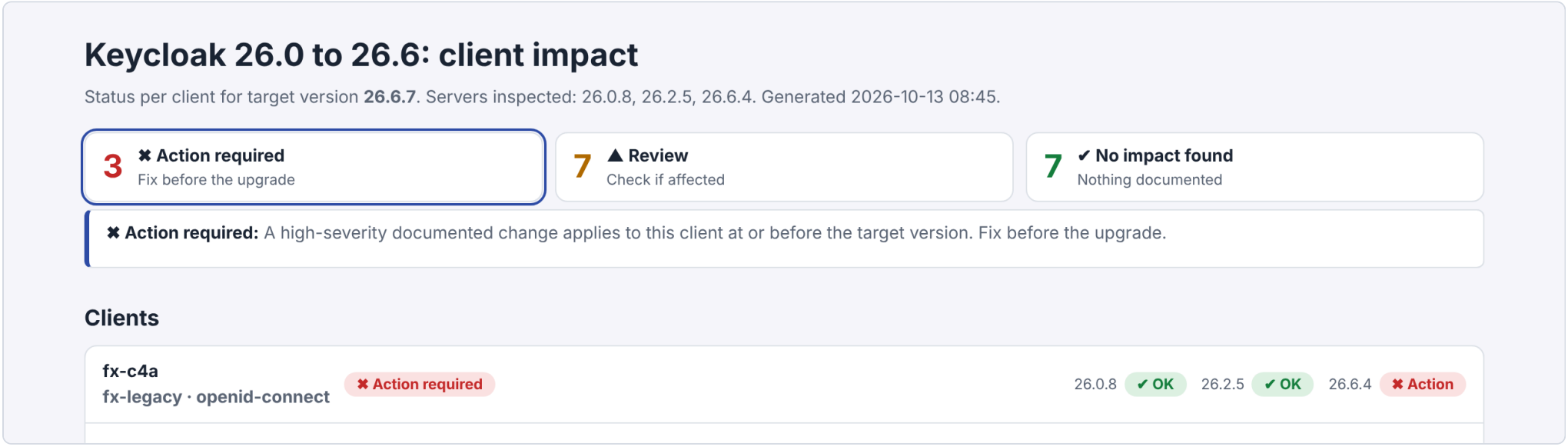
Result on the three lab servers: 19 checks per version, 57 in total. 54 match the documented expectation, 3 are not exercised (token refresh in flask-oidc). Nothing failed. New libraries are added by one runner file plus one catalog entry.

Dashboard (1 of 4): the status at a glance

One row per client, three states. Hovering a state explains it in the line below; the default line explains the source references.



Default view. The line under the three tiles explains "UG" and the paragraph numbers.



Hovering "Action required": the explanation changes, the tiles stay compact.

Dashboard (2 of 4): per client, with the document behind every finding

Excerpt: two of the 17 clients. Each rule names its Upgrading Guide paragraph; the green line is a result confirmed on real servers.

Clients

fx-c4a
fx-legacy · openid-connect
✖ Action required

26.0.8 ✔ OK 26.2.5 ✔ OK 26.6.4 ✖ Action

Rule	What changes	Found	Official document (UG = Upgrading Guide)
C4a	**Hostname wildcard in a redirect URI no longer works** applies from 26.4.13 (active on 26.6.4)	wildcard in host part `https://*.example.org/*`	UG26.4 §2.2.1; UG26.6 §2.5.1

fx-multi
fx-legacy · openid-connect
✖ Action required

26.0.8 ✔ OK 26.2.5 ✔ OK 26.6.4 ✖ Action

Rule	What changes	Found	Official document (UG = Upgrading Guide)
C4a	**Hostname wildcard in a redirect URI no longer works** applies from 26.4.13 (active on 26.6.4)	wildcard in host part `https://*.example.org/cb?code=1`	UG26.4 §2.2.1; UG26.6 §2.5.1
C5	**OIDC parameter (state/code/session_state) inside a registered redirect URI, or the compatibility attribute is set** applies from 26.6.7 (not yet on any inspected server)	parameter(s) code in registered URI `https://*.example.org/cb?code=1`	UG26.6 §2.1.2
C12	**Web origin is not a plain origin; invalid Origin requests are rejected with 403** applies from 26.6.3 (active on 26.6.4)	web origin is not scheme://host[:port] `https://app.example.org/x`	UG26.6 §2.9.2
C16	**Direct access grants (ROPC) enabled: invalid_grant now returns HTTP 400 instead of 401** applies from 26.6.2 (active on 26.6.4)	directAccessGrantsEnabled=true ✔ Confirmed on real servers - http_status: `401` on 26.0.8, 26.2.5 → `400` on 26.6.4 (seen by http-probe)	UG26.6 §2.10.38

Dashboard (3 of 4): libraries on each server version

The same check for each library on 26.0.8, 26.2.5 and 26.6.4. A deprecated library version stays visible, with reason and successor.

Libraries on each server version

7 libraries ran against 26.0.8, 26.2.5, 26.6.4. Checks: 54 match, 3 not exercised.

http-probe python · oidc · no library	26.0.8	✔ 3/3 match	26.2.5	✔ 3/3 match	26.6.4 ✔ 3/3 match
plain-http-code python · oidc · no library	26.0.8	✔ 3/3 match	26.2.5	✔ 3/3 match	26.6.4 ✔ 3/3 match
passport-oauth2 node · oidc · 1.8.0	26.0.8	✔ 3/3 match	26.2.5	✔ 3/3 match	26.6.4 ✔ 3/3 match
flask-oidc python · oidc · 2.4.0	26.0.8	✔ 2/3 match	26.2.5	✔ 2/3 match	26.6.4 ✔ 2/3 match
samlify node · saml · 2.13.1	26.0.8	✔ 2/2 match	26.2.5	✔ 2/2 match	26.6.4 ✔ 2/2 match
python3-saml python · saml · 1.16.0	26.0.8	✔ 2/2 match	26.2.5	✔ 2/2 match	26.6.4 ✔ 2/2 match
better-auth node · oidc · 1.7.1	26.0.8	✔ 3/3 match	26.2.5	✔ 3/3 match	26.6.4 ✔ 3/3 match

samlify-legacy <2.10.0 node · saml · deprecated deprecated CVE-2025-47949 (signature wrapping, critical) fixed in 2.10.0. Upgrade the library; teams on older versions should plan it now.

Catalog entry only, no runner: shows how a library version is marked deprecated without changing code.

Dashboard (4 of 4): what the servers do differently

Values that changed between the lab servers, who observed them, and the official document.

What the servers do differently, seen on real runs

Observed values that change between the inspected servers. Libraries that agree are listed together.

Check	Value	Observed	Seen by	Official document
C16 Direct access grant with wrong password	http_status	`401` on 26.0.8, 26.2.5 → `400` on 26.6.4	http-probe	UG26.6 §2.10.38
D3 Path probes: '//', '..', ';' (encoded slash is recorded only)	dot_dot	`200` on 26.0.8, 26.2.5 → `400` on 26.6.4	http-probe	UG26.4 §2.6.1 ('..', '//' from 26.4.4); semicolon from 26.4.9 (design v0.3 C3; UG26.4 §2.11.3; UG26.6 §2.10.48)
D3 Path probes: '//', '..', ';' (encoded slash is recorded only)	double_slash	`200` on 26.0.8, 26.2.5 → `400` on 26.6.4	http-probe	UG26.4 §2.6.1 ('..', '//' from 26.4.4); semicolon from 26.4.9 (design v0.3 C3; UG26.4 §2.11.3; UG26.6 §2.10.48)
D3 Path probes: '//', '..', ';' (encoded slash is recorded only)	semicolon	`200` on 26.0.8, 26.2.5 → `400` on 26.6.4	http-probe	UG26.4 §2.6.1 ('..', '//' from 26.4.4); semicolon from 26.4.9 (design v0.3 C3; UG26.4 §2.11.3; UG26.6 §2.10.48)
F4 Format of session_state and sid	session_state_format	`uuid` on 26.0.8, 26.2.5 → `base64-24` on 26.6.4	plain-http-code, passport-oauth2, flask-oidc	UG26.6 §2.10.11
F4 Format of session_state and sid	sid_format	`uuid` on 26.0.8, 26.2.5 → `base64-24` on 26.6.4	plain-http-code, passport-oauth2, flask-oidc, better-auth	UG26.6 §2.10.11

Sources: fx-26.0.8-fx-baseline.json, fx-26.0.8-fx-legacy.json, fx-26.2.5-fx-baseline.json, fx-26.2.5-fx-legacy.json, fx-26.6.4-fx-baseline.json, fx-26.6.4-fx-legacy.json, runners-26.0.8.json, runners-26.2.5.json, runners-26.6.4.json. Rules cite the Red Hat build of Keycloak Upgrading Guides (UG).

The three changes were observed on running servers, not only read from the guides: wrong-password status 401 → 400 on 26.6.4, session identifiers UUID → 24-character base64 on 26.6.4, and paths with `//`, `..` or `;` answered 200 → 400 on 26.6.4. The 26.4.x thresholds come from the guides; no 26.4 server was run.

What the library runs taught us

Findings that teams will hit in their own code, independent of the Keycloak version.

samlify

Signs nothing by default, but Keycloak publishes `WantAuthnRequestsSigned=true` for these clients, so the library needs a key and certificate. Since 2.6 it also needs a schema validator package. Same on all three versions.

python3-saml

Tolerated unsigned requests here. Needs lxml and xmlsec; on RHEL 9 the xmlsec1 packages must be on the mirror.

better-auth

Works through its generic OAuth plugin. Declares Node 20.19 or newer for some dependencies (warnings on Node 18). Token calls need an account id.

passport-oauth2

Does not validate the ID token by design; the application must check issuer and audience itself. A real finding for review, not a defect.

Honest limits

- Lab servers are upstream Keycloak 26.0.8, 26.2.5 and 26.6.4; patch numbers differ from RHBK. Not yet run on 26.4, on 26.6.6/26.6.7, on staging or production, nor on a real client export.
- Not exercised: flask-oidc refresh, better-auth with SAML, Keycloak acting as SAML service provider towards an external identity provider.
- The dashboard is the evidence layer. The interactive test application (data-center switch, hidden code-snippet panel, deprecation badge) is not built yet.
- Go, Java and .NET runners are deferred until the on-site presentation has shown which direction the teams want.

Proposed on-site step

Install on an air-gapped host, present, and let the reaction decide the next stage.

They like it

Point it at the staging realm: read-only inventory first, then the runner realm. Keep the dashboard as the weekly view for team leads.

They do not like it

The inventory and the evidence table are small and separate. Keep what helps, drop the rest. Nothing else depends on it.

They want more libraries

Add NPM and PyPI libraries on site: one runner file and one catalog entry each. The AI prompt in the kit explains the procedure.

Open decision

Who creates the test realm on the real staging server? The runners need a realm with a test user and test clients, which requires administrator rights. Either the Keycloak team imports the supplied realm file, or the team provides a dedicated realm and clients. The inventory needs only a read-only service account (`view-clients`, `view-realm`).

Kit contents: this briefing, a one-page install checklist, a demo script, an AI continuation prompt, and the complete project (zip or Git repository).

Keycloak 26.0.8: what the tool found, client by client

17 clients checked in two test realms. Every client matched its expected result (rule set compared exactly).

Realm	Client	Type	Problems flagged (rule IDs, see the rules table)	Verdict
fx-legacy	**fx-c11**	openid-connect	C11	as expected
fx-legacy	**fx-c12**	openid-connect	C12	as expected
fx-legacy	**fx-c16**	openid-connect	C16	as expected
fx-legacy	**fx-c4a**	openid-connect	C4a	as expected
fx-legacy	**fx-c4b**	openid-connect	C4b	as expected
fx-legacy	**fx-c5**	openid-connect	C5	as expected
fx-legacy	**fx-c6**	openid-connect	C6	as expected
fx-legacy	**fx-c7**	openid-connect	C7	as expected
fx-legacy	**fx-c8**	openid-connect	C8	as expected
fx-legacy	**fx-multi**	openid-connect	C12 C16 C4a C5	as expected
fx-legacy	**fx-p1**	public	none	as expected
fx-legacy	**kc-inventory**	openid-connect	none	as expected
fx-baseline	**fx-bearer**	bearer-only	none	as expected
fx-baseline	**fx-clean**	openid-connect	none	as expected
fx-baseline	**fx-saml**	saml	none	as expected
fx-baseline	**fx-svc**	openid-connect	none	as expected
fx-baseline	**kc-inventory**	openid-connect	none	as expected

Server discovery: issuer `https://192.0.2.10:8460/realms/fx-legacy` matches the URL it was fetched from; root RFC 8414 path answered HTTP 404 (expected: this path exists from 26.4.2). Information-only rows (C15, client authentication inventory) are left out here and appear in the full report on the next pages.

Keycloak 26.0.8 · realm fx-legacy

11 test clients, each with one legacy setting

Server 26.0.8, generated 2026-10-11T06:09:35Z. **10 of 12 clients have findings** (info-level inventory rows excluded). Discovery/readiness findings: 0.

Client findings

Realm	Client	Sev	Rule	Since	What	Detail	Evidence
fx-legacy	fx-c11	medium	C11	26.4.12 (on server: **not yet**)	Client issues lightweight access tokens: UserInfo rejects them (401)	client.use.lightweight.access.token.enabled=true; fine unless a consumer calls UserInfo with this token [UG26.4 §2.3.4; UG26.6 §2.6.11]	
fx-legacy	fx-c11	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c12	low	C12	26.6.3 (on server: **not yet**)	Web origin is not a plain origin; invalid Origin requests are rejected with 403	web origin is not scheme://host[:port] [UG26.6 §2.9.2]	`https://app.example.org/`
fx-legacy	fx-c12	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c16	low	C16	26.6.2 (on server: **not yet**)	Direct access grants (ROPC) enabled: invalid_grant now returns HTTP 400 instead of 401	directAccessGrantsEnabled=true [UG26.6 §2.10.38]	
fx-legacy	fx-c16	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c4a	high	C4a	26.4.13 (on server: **not yet**)	Hostname wildcard in a redirect URI no longer works	wildcard in host part [UG26.4 §2.2.1; UG26.6 §2.5.1]	`https://*.example.org/*`
fx-legacy	fx-c4a	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c4b	medium	C4b	26.4.13 (on server: **not yet**)	'https://host*' is now treated as 'https://host/*'	wildcard directly after host [UG26.4 §2.2.1; UG26.6 §2.5.1]	`https://host.example.org*`

fx-legacy	fx-c4b	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c5	high	C5	26.6.7 (on server: **not yet**)	OIDC parameter (state/code/session_state) inside a registered redirect URI, or the compatibility attribute is set	parameter(s) state in registered URI [UG26.6 §2.1.2]	`https://app.example.org/cb?state=x`
fx-legacy	fx-c5	high	C5	26.6.7 (on server: **not yet**)	OIDC parameter (state/code/session_state) inside a registered redirect URI, or the compatibility attribute is set	attribute allow.oidc.params.in.redirect.uris=true (deprecated, removed in 27) [UG26.6 §2.1.2]	
fx-legacy	fx-c5	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c6	medium	C6	26.6.2 (on server: **not yet**)	'http' URL in a field that the secure-client-uris executor requires to be https	post.logout.redirect.uris uses http (executor not found in realm policies) [UG26.6 §2.6.4]	`http://app.example.org/out`
fx-legacy	fx-c6	medium	C6	26.6.2 (on server: **not yet**)	'http' URL in a field that the secure-client-uris executor requires to be https	logoUri uses http (executor not found in realm policies) [UG26.6 §2.6.4]	`http://app.example.org/logo.png`
fx-legacy	fx-c6	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c7	medium	C7	26.2 (on server: **not yet**)	JWT client authentication: only a single audience accepted	clientAuthenticatorType=client-jwt [UG26.2 §2.1.4]	
fx-legacy	fx-c7	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-jwt [UG26.6 §2.10.29]	
fx-legacy	fx-c8	medium	C8	26.2 (on server: **not yet**)	Standard token exchange enabled on this client	standard.token.exchange.enabled=true [UG26.2 §2.1.6; UG26.6 §2.10.39]	
fx-legacy	fx-c8	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-multi	high	C4a	26.4.13 (on server: **not yet**)	Hostname wildcard in a redirect URI no longer works	wildcard in host part [UG26.4 §2.2.1; UG26.6 §2.5.1]	`https://*.example.org/cb?code=1`

fx-legacy	fx-multi	high	C5	26.6.7 (on server: **not yet**)	OIDC parameter (state/code/session_state) inside a registered redirect URI, or the compatibility attribute is set	parameter(s) code in registered URI [UG26.6 §2.1.2]	`https://*.example.org/cb?code=1`
fx-legacy	fx-multi	low	C12	26.6.3 (on server: **not yet**)	Web origin is not a plain origin; invalid Origin requests are rejected with 403	web origin is not scheme://host[:port] [UG26.6 §2.9.2]	`https://app.example.org/x`
fx-legacy	fx-multi	low	C16	26.6.2 (on server: **not yet**)	Direct access grants (ROPC) enabled: invalid_grant now returns HTTP 400 instead of 401	directAccessGrantsEnabled=true [UG26.6 §2.10.38]	
fx-legacy	fx-multi	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-p1	info	P1	- (on server: ?)	Public client: outside the confidential-client runner matrix, review manually	publicClient=true [design §4]	
fx-legacy	kc-inventory	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	

Discovery audit (D1/D2)

Route	Realm	Issuer	OIDC discovery	RFC 8414 root
external	fx-legacy	https://192.0.2.10:8460/realms/fx-legacy	200	404
D2 Root /.well-known/oauth-authorization-server path not reachable through this route - HTTP 404 on /.well-known/oauth-authorization-server/realms/fx-legacy (expected: this path exists from 26.4.2)				

Read access of the inventory account (X1)

Call	HTTP
serverinfo	200
realm [fx-legacy]	200
clients [fx-legacy]	200
client-policies/profiles [fx-legacy]	200
client-policies/policies [fx-legacy]	200
identity-provider/instances [fx-legacy]	403

Keycloak 26.0.8 · realm fx-baseline clean clients, expected: no problem findings

Server 26.0.8, generated 2026-10-11T06:09:35Z. **0 of 5 clients have findings** (info-level inventory rows excluded). Discovery/readiness findings: 0.

Client findings

Realm	Client	Sev	Rule	Since	What	Detail	Evidence
fx-baseline	fx-clean	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-baseline	fx-svc	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-baseline	kc-inventory	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	

Discovery audit (D1/D2)

Route	Realm	Issuer	OIDC discovery	RFC 8414 root
external	fx-baseline	https://192.0.2.10:8460/realms/fx-baseline	200	404
D2 Root /.well-known/oauth-authorization-server path not reachable through this route - HTTP 404 on /.well-known/oauth-authorization-server/realms/fx-baseline (expected: this path exists from 26.4.2)				

Read access of the inventory account (X1)

Call	HTTP
serverinfo	200
realm [fx-baseline]	200
clients [fx-baseline]	200
client-policies/profiles [fx-baseline]	200
client-policies/policies [fx-baseline]	200
identity-provider/instances [fx-baseline]	403

Keycloak 26.2.5: what the tool found, client by client

17 clients checked in two test realms. Every client matched its expected result (rule set compared exactly).

Realm	Client	Type	Problems flagged (rule IDs, see the rules table)	Verdict
fx-legacy	**fx-c11**	openid-connect	C11	as expected
fx-legacy	**fx-c12**	openid-connect	C12	as expected
fx-legacy	**fx-c16**	openid-connect	C16	as expected
fx-legacy	**fx-c4a**	openid-connect	C4a	as expected
fx-legacy	**fx-c4b**	openid-connect	C4b	as expected
fx-legacy	**fx-c5**	openid-connect	C5	as expected
fx-legacy	**fx-c6**	openid-connect	C6	as expected
fx-legacy	**fx-c7**	openid-connect	C7	as expected
fx-legacy	**fx-c8**	openid-connect	C8	as expected
fx-legacy	**fx-multi**	openid-connect	C12 C16 C4a C5	as expected
fx-legacy	**fx-p1**	public	none	as expected
fx-legacy	**kc-inventory**	openid-connect	none	as expected
fx-baseline	**fx-bearer**	bearer-only	none	as expected
fx-baseline	**fx-clean**	openid-connect	none	as expected
fx-baseline	**fx-saml**	saml	none	as expected
fx-baseline	**fx-svc**	openid-connect	none	as expected
fx-baseline	**kc-inventory**	openid-connect	none	as expected

Server discovery: issuer `https://192.0.2.10:8462/realms/fx-legacy` matches the URL it was fetched from; root RFC 8414 path answered HTTP 404 (expected: this path exists from 26.4.2). Information-only rows (C15, client authentication inventory) are left out here and appear in the full report on the next pages.

Keycloak 26.2.5 · realm fx-legacy

11 test clients, each with one legacy setting

Server 26.2.5, generated 2026-10-11T06:09:36Z. **10 of 12 clients have findings** (info-level inventory rows excluded). Discovery/readiness findings: 0.

Client findings

Realm	Client	Sev	Rule	Since	What	Detail	Evidence
fx-legacy	fx-c11	medium	C11	26.4.12 (on server: **not yet**)	Client issues lightweight access tokens: UserInfo rejects them (401)	client.use.lightweight.access.token.enabled=true; fine unless a consumer calls UserInfo with this token [UG26.4 §2.3.4; UG26.6 §2.6.11]	
fx-legacy	fx-c11	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c12	low	C12	26.6.3 (on server: **not yet**)	Web origin is not a plain origin; invalid Origin requests are rejected with 403	web origin is not scheme://host[:port] [UG26.6 §2.9.2]	`https://app.example.org/`
fx-legacy	fx-c12	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c16	low	C16	26.6.2 (on server: **not yet**)	Direct access grants (ROPC) enabled: invalid_grant now returns HTTP 400 instead of 401	directAccessGrantsEnabled=true [UG26.6 §2.10.38]	
fx-legacy	fx-c16	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c4a	high	C4a	26.4.13 (on server: **not yet**)	Hostname wildcard in a redirect URI no longer works	wildcard in host part [UG26.4 §2.2.1; UG26.6 §2.5.1]	`https://*.example.org/*`
fx-legacy	fx-c4a	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c4b	medium	C4b	26.4.13 (on server: **not yet**)	'https://host*' is now treated as 'https://host/*'	wildcard directly after host [UG26.4 §2.2.1; UG26.6 §2.5.1]	`https://host.example.org*`

fx-legacy	fx-c4b	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c5	high	C5	26.6.7 (on server: **not yet**)	OIDC parameter (state/code/session_state) inside a registered redirect URI, or the compatibility attribute is set	parameter(s) state in registered URI [UG26.6 §2.1.2]	`https://app.example.org/cb?state=x`
fx-legacy	fx-c5	high	C5	26.6.7 (on server: **not yet**)	OIDC parameter (state/code/session_state) inside a registered redirect URI, or the compatibility attribute is set	attribute allow.oidc.params.in.redirect.uris=true (deprecated, removed in 27) [UG26.6 §2.1.2]	
fx-legacy	fx-c5	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c6	medium	C6	26.6.2 (on server: **not yet**)	'http' URL in a field that the secure-client-uris executor requires to be https	post.logout.redirect.uris uses http (executor not found in realm policies) [UG26.6 §2.6.4]	`http://app.example.org/out`
fx-legacy	fx-c6	medium	C6	26.6.2 (on server: **not yet**)	'http' URL in a field that the secure-client-uris executor requires to be https	logoUri uses http (executor not found in realm policies) [UG26.6 §2.6.4]	`http://app.example.org/logo.png`
fx-legacy	fx-c6	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c7	medium	C7	26.2 (on server: yes)	JWT client authentication: only a single audience accepted	clientAuthenticatorType=client-jwt [UG26.2 §2.1.4]	
fx-legacy	fx-c7	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-jwt [UG26.6 §2.10.29]	
fx-legacy	fx-c8	medium	C8	26.2 (on server: yes)	Standard token exchange enabled on this client	standard.token.exchange.enabled=true [UG26.2 §2.1.6; UG26.6 §2.10.39]	
fx-legacy	fx-c8	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-multi	high	C4a	26.4.13 (on server: **not yet**)	Hostname wildcard in a redirect URI no longer works	wildcard in host part [UG26.4 §2.2.1; UG26.6 §2.5.1]	`https://*.example.org/cb?code=1`

fx-legacy	fx-multi	high	C5	26.6.7 (on server: **not yet**)	OIDC parameter (state/code/session_state) inside a registered redirect URI, or the compatibility attribute is set	parameter(s) code in registered URI [UG26.6 §2.1.2]	`https://*.example.org/cb?code=1`
fx-legacy	fx-multi	low	C12	26.6.3 (on server: **not yet**)	Web origin is not a plain origin; invalid Origin requests are rejected with 403	web origin is not scheme://host[:port] [UG26.6 §2.9.2]	`https://app.example.org/x`
fx-legacy	fx-multi	low	C16	26.6.2 (on server: **not yet**)	Direct access grants (ROPC) enabled: invalid_grant now returns HTTP 400 instead of 401	directAccessGrantsEnabled=true [UG26.6 §2.10.38]	
fx-legacy	fx-multi	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-p1	info	P1	- (on server: ?)	Public client: outside the confidential-client runner matrix, review manually	publicClient=true [design §4]	
fx-legacy	kc-inventory	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	

Discovery audit (D1/D2)

Route	Realm	Issuer	OIDC discovery	RFC 8414 root
external	fx-legacy	https://192.0.2.10:8462/realms/fx-legacy	200	404
D2 Root /.well-known/oauth-authorization-server path not reachable through this route - HTTP 404 on /.well-known/oauth-authorization-server/realms/fx-legacy (expected: this path exists from 26.4.2)				

Read access of the inventory account (X1)

Call	HTTP
serverinfo	200
realm [fx-legacy]	200
clients [fx-legacy]	200
client-policies/profiles [fx-legacy]	200
client-policies/policies [fx-legacy]	200
identity-provider/instances [fx-legacy]	403

Keycloak 26.2.5 · realm fx-baseline clean clients, expected: no problem findings

Server 26.2.5, generated 2026-10-11T06:09:36Z. **0 of 5 clients have findings** (info-level inventory rows excluded). Discovery/readiness findings: 0.

Client findings

Realm	Client	Sev	Rule	Since	What	Detail	Evidence
fx-baseline	fx-clean	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-baseline	fx-svc	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-baseline	kc-inventory	info	C15	26.6.2 (on server: **not yet**)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	

Discovery audit (D1/D2)

Route	Realm	Issuer	OIDC discovery	RFC 8414 root
external	fx-baseline	https://192.0.2.10:8462/realms/fx-baseline	200	404
D2 Root /.well-known/oauth-authorization-server path not reachable through this route - HTTP 404 on /.well-known/oauth-authorization-server/realms/fx-baseline (expected: this path exists from 26.4.2)				

Read access of the inventory account (X1)

Call	HTTP
serverinfo	200
realm [fx-baseline]	200
clients [fx-baseline]	200
client-policies/profiles [fx-baseline]	200
client-policies/policies [fx-baseline]	200
identity-provider/instances [fx-baseline]	403

Keycloak 26.6.4: what the tool found, client by client

17 clients checked in two test realms. Every client matched its expected result (rule set compared exactly).

Realm	Client	Type	Problems flagged (rule IDs, see the rules table)	Verdict
fx-legacy	**fx-c11**	openid-connect	C11	as expected
fx-legacy	**fx-c12**	openid-connect	C12	as expected
fx-legacy	**fx-c16**	openid-connect	C16	as expected
fx-legacy	**fx-c4a**	openid-connect	C4a	as expected
fx-legacy	**fx-c4b**	openid-connect	C4b	as expected
fx-legacy	**fx-c5**	openid-connect	C5	as expected
fx-legacy	**fx-c6**	openid-connect	C6	as expected
fx-legacy	**fx-c7**	openid-connect	C7	as expected
fx-legacy	**fx-c8**	openid-connect	C8	as expected
fx-legacy	**fx-multi**	openid-connect	C12 C16 C4a C5	as expected
fx-legacy	**fx-p1**	public	none	as expected
fx-legacy	**kc-inventory**	openid-connect	none	as expected
fx-baseline	**fx-bearer**	bearer-only	none	as expected
fx-baseline	**fx-clean**	openid-connect	none	as expected
fx-baseline	**fx-saml**	saml	none	as expected
fx-baseline	**fx-svc**	openid-connect	none	as expected
fx-baseline	**kc-inventory**	openid-connect	none	as expected

Server discovery: issuer `https://192.0.2.10:8466/realms/fx-legacy` matches the URL it was fetched from; root RFC 8414 path answered HTTP 200. Information-only rows (C15, client authentication inventory) are left out here and appear in the full report on the next pages.

Keycloak 26.6.4 · realm fx-legacy

11 test clients, each with one legacy setting

Server 26.6.4, generated 2026-10-11T06:09:37Z. **10 of 12 clients have findings** (info-level inventory rows excluded). Discovery/readiness findings: 0.

Client findings

Realm	Client	Sev	Rule	Since	What	Detail	Evidence
fx-legacy	fx-c11	medium	C11	26.4.12 (on server: yes)	Client issues lightweight access tokens: UserInfo rejects them (401)	client.use.lightweight.access.token.enabled=true; fine unless a consumer calls UserInfo with this token [UG26.4 §2.3.4; UG26.6 §2.6.11]	
fx-legacy	fx-c11	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c12	low	C12	26.6.3 (on server: yes)	Web origin is not a plain origin; invalid Origin requests are rejected with 403	web origin is not scheme://host[:port] [UG26.6 §2.9.2]	`https://app.example.org/`
fx-legacy	fx-c12	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c16	low	C16	26.6.2 (on server: yes)	Direct access grants (ROPC) enabled: invalid_grant now returns HTTP 400 instead of 401	directAccessGrantsEnabled=true [UG26.6 §2.10.38]	
fx-legacy	fx-c16	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c4a	high	C4a	26.4.13 (on server: yes)	Hostname wildcard in a redirect URI no longer works	wildcard in host part [UG26.4 §2.2.1; UG26.6 §2.5.1]	`https://*.example.org/*`
fx-legacy	fx-c4a	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c4b	medium	C4b	26.4.13 (on server: yes)	'https://host*' is now treated as 'https://host/*'	wildcard directly after host [UG26.4 §2.2.1; UG26.6 §2.5.1]	`https://host.example.org*`

fx-legacy	fx-c4b	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c5	high	C5	26.6.7 (on server: **not yet**)	OIDC parameter (state/code/session_state) inside a registered redirect URI, or the compatibility attribute is set	parameter(s) state in registered URI [UG26.6 §2.1.2]	`https://app.example.org/cb?state=x`
fx-legacy	fx-c5	high	C5	26.6.7 (on server: **not yet**)	OIDC parameter (state/code/session_state) inside a registered redirect URI, or the compatibility attribute is set	attribute allow.oidc.params.in.redirect.uris=true (deprecated, removed in 27) [UG26.6 §2.1.2]	
fx-legacy	fx-c5	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c6	medium	C6	26.6.2 (on server: yes)	'http' URL in a field that the secure-client-uris executor requires to be https	post.logout.redirect.uris uses http (executor not found in realm policies) [UG26.6 §2.6.4]	`http://app.example.org/out`
fx-legacy	fx-c6	medium	C6	26.6.2 (on server: yes)	'http' URL in a field that the secure-client-uris executor requires to be https	logoUri uses http (executor not found in realm policies) [UG26.6 §2.6.4]	`http://app.example.org/logo.png`
fx-legacy	fx-c6	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-c7	medium	C7	26.2 (on server: yes)	JWT client authentication: only a single audience accepted	clientAuthenticatorType=client-jwt [UG26.2 §2.1.4]	
fx-legacy	fx-c7	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-jwt [UG26.6 §2.10.29]	
fx-legacy	fx-c8	medium	C8	26.2 (on server: yes)	Standard token exchange enabled on this client	standard.token.exchange.enabled=true [UG26.2 §2.1.6; UG26.6 §2.10.39]	
fx-legacy	fx-c8	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-multi	high	C4a	26.4.13 (on server: yes)	Hostname wildcard in a redirect URI no longer works	wildcard in host part [UG26.4 §2.2.1; UG26.6 §2.5.1]	`https://*.example.org/cb?code=1`

fx-legacy	fx-multi	high	C5	26.6.7 (on server: **not yet**)	OIDC parameter (state/code/session_state) inside a registered redirect URI, or the compatibility attribute is set	parameter(s) code in registered URI [UG26.6 §2.1.2]	`https://*.example.org/cb?code=1`
fx-legacy	fx-multi	low	C12	26.6.3 (on server: yes)	Web origin is not a plain origin; invalid Origin requests are rejected with 403	web origin is not scheme://host[:port] [UG26.6 §2.9.2]	`https://app.example.org/x`
fx-legacy	fx-multi	low	C16	26.6.2 (on server: yes)	Direct access grants (ROPC) enabled: invalid_grant now returns HTTP 400 instead of 401	directAccessGrantsEnabled=true [UG26.6 §2.10.38]	
fx-legacy	fx-multi	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-legacy	fx-p1	info	P1	- (on server: ?)	Public client: outside the confidential-client runner matrix, review manually	publicClient=true [design §4]	
fx-legacy	kc-inventory	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	

Discovery audit (D1/D2)

Route	Realm	Issuer	OIDC discovery	RFC 8414 root
external	fx-legacy	https://192.0.2.10:8466/realms/fx-legacy	200	200

Read access of the inventory account (X1)

Call	HTTP
serverinfo	200
realm [fx-legacy]	200
clients [fx-legacy]	200
client-policies/profiles [fx-legacy]	200
client-policies/policies [fx-legacy]	200
identity-provider/instances [fx-legacy]	403

Keycloak 26.6.4 · realm fx-baseline clean clients, expected: no problem findings

Server 26.6.4, generated 2026-10-11T06:09:37Z. **0 of 5 clients have findings** (info-level inventory rows excluded). Discovery/readiness findings: 0.

Client findings

Realm	Client	Sev	Rule	Since	What	Detail	Evidence
fx-baseline	fx-clean	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-baseline	fx-svc	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	
fx-baseline	kc-inventory	info	C15	26.6.2 (on server: yes)	Client authentication method inventory (enforced for newly registered clients)	authentication method: client-secret [UG26.6 §2.10.29]	

Discovery audit (D1/D2)

Route	Realm	Issuer	OIDC discovery	RFC 8414 root
external	fx-baseline	https://192.0.2.10:8466/realms/fx-baseline	200	200

Read access of the inventory account (X1)

Call	HTTP
serverinfo	200
realm [fx-baseline]	200
clients [fx-baseline]	200
client-policies/profiles [fx-baseline]	200
client-policies/policies [fx-baseline]	200
identity-provider/instances [fx-baseline]	403